

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5 TOTAL MARKS: 50

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I Daniel Jesuraji J (192565085) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Annexure A
Industry Problem-Solving Task

1. A multinational enterprise is deploying IPSec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
- B. Design packet flow with appropriate IPSec modes (transport/tunnel)
- C. Justify protocol selection for different data types
- D. Evaluate performance vs security trade-offs

A multinational enterprise can use **IPSec** to secure communication between branch offices over the public Internet. IPSec provides **authentication, integrity, confidentiality, and anti-replay protection**. The two main protocols are **Authentication Header (AH)** and **Encapsulating Security Payload (ESP)**.

A. Traffic requiring AH, ESP, or both

Traffic / Requirement	Recommended Protocol	Reason
Data requiring integrity and authentication only	AH	Protects packet integrity and authenticates the source
Confidential business data	ESP	Provides encryption, integrity, and authentication
Financial/customer information	ESP	Confidentiality is essential

Traffic / Requirement	Recommended Protocol	Reason
Highly sensitive traffic requiring additional authentication	ESP + AH	Provides both ESP protection and AH authentication

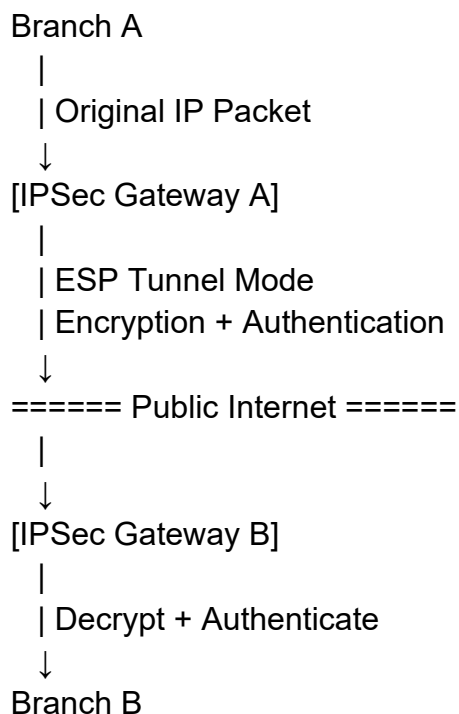
AH: Provides authentication and integrity but does not provide encryption.
 ESP: Provides confidentiality through encryption, along with integrity and authentication.

For most modern enterprise deployments, ESP is preferred, especially when sensitive information is transmitted.

B. Packet flow and IPSec modes

For communication between two branch offices, Tunnel Mode is recommended.

Packet flow:



In Tunnel Mode, the complete original IP packet is encapsulated and protected inside a new IP packet.

For host-to-host communication within a trusted network, Transport Mode can be

used:

Original IP Header
+
ESP Header
+
Encrypted Payload
+
ESP Authentication

Thus, Tunnel Mode is more suitable for branch-to-branch VPN communication, while Transport Mode is suitable for direct host-to-host protection.

B. Justification of protocol selection

ESP should be the primary protocol because branch-office traffic may contain confidential business information, credentials, financial data, and internal communications.

- AH → integrity + authentication
 - ESP → confidentiality + integrity + authentication
 - ESP + AH → maximum protection when both services are specifically required
- Since ESP can provide the required confidentiality and integrity in one protocol, using ESP alone generally avoids unnecessary overhead compared with combining AH and ESP.

D. Performance vs Security Trade-offs

Option	Security	Performance	Suitable Use
AH	Medium	Higher	Integrity/authentication only
ESP	High	Moderate	Confidential business traffic
AH + ESP	Very High	Lower	Highly sensitive environments
ESP Tunnel Mode	High	Moderate	Branch-to-branch VPN

Conclusion:

The enterprise should primarily configure ESP in Tunnel Mode between branch-office IPSec gateways. ESP provides confidentiality, integrity, authentication, and anti-replay protection while maintaining a reasonable performance level. AH can be considered where authentication and integrity are required without confidentiality. This approach provides a good balance between security, scalability, and network performance.

2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
- B. Design an automated key management mechanism (e.g., IKE-based)
- C. Propose a strategy for key renewal and revocation
- D. Evaluate scalability and fault tolerance

An organization facing frequent expired or mismatched keys should use an automated **Security Association (SA) management and Internet Key Exchange (IKE)** mechanism. IKE automatically negotiates security parameters, authenticates peers, establishes SAs, and generates fresh session keys. This reduces manual configuration errors and improves scalability.

A. Analysis of Current SA Lifecycle Issues

The major problems in the existing IPSec implementation are:

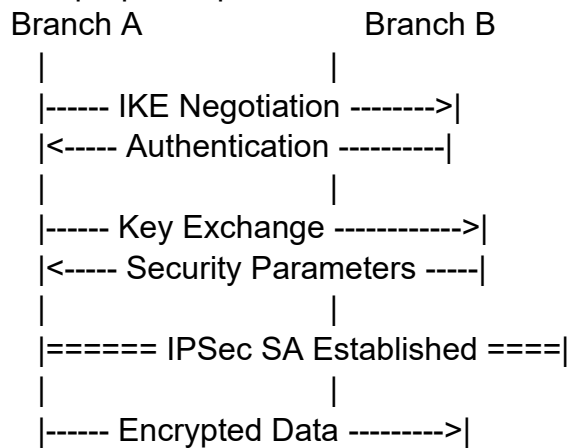
- 1. **Expired keys** – SAs may expire before new keys are established.
- 2. **Mismatched keys** – Different devices may use different encryption or authentication keys.
- 3. **Manual key configuration** – Manual management increases configuration errors.
- 4. **Inconsistent security parameters** – Devices may have different encryption, authentication, or lifetime settings.
- 5. **Poor scalability** – Managing keys manually becomes difficult when the number of branch offices increases.

These issues can cause communication failures and reduce the overall security of the IPSec network.

B. Automated Key Management Using IKE

The organization should implement **IKE (Internet Key Exchange)** to automate the creation and management of IPSec Security Associations.

The proposed process is:



Working:

1. The two IPSec gateways initiate an IKE negotiation.
 2. They agree on security parameters such as encryption and authentication algorithms.
 3. The gateways authenticate each other.
 4. IKE securely establishes shared keying material.
 5. IPSec Security Associations are created.
 6. The negotiated keys are used to protect data communication.
 7. IKE can automatically create new SAs when existing ones approach their lifetime.
- This eliminates the need for manually entering and updating IPSec keys.

C. Strategy for Key Renewal and Revocation

The following strategy should be implemented:

- Set appropriate **SA lifetime limits**.
- Automatically generate **new keys before the current SA expires**.
- Use IKE to perform automatic rekeying.
- Immediately revoke compromised or unauthorized keys.
- Remove expired SAs from the Security Association Database.
- Maintain centralized logging of key-management events.
- Use strong authentication for all IPSec gateways.

Automatic rekeying ensures continuous communication while reducing the risk associated with long-term use of the same keys.

D. Scalability and Fault Tolerance

An IKE-based solution is highly suitable for a large enterprise because key establishment and SA management are automated.

Scalability:

- Reduces manual key management.
- Supports multiple branch-office gateways.
- Automatically establishes SAs when required.
- Makes key renewal easier as the network grows.

Fault Tolerance:

- Redundant IPSec gateways can be deployed.
- Backup gateways can establish new SAs when a primary gateway fails.
- Automatic rekeying prevents sudden communication failure caused by expired keys.
- Monitoring and logging can detect SA or authentication failures.

Conclusion

The organization should adopt an **IKE-based automated IPSec key-management system**. IKE can automate authentication, key exchange, SA establishment, and rekeying. Regular key renewal, timely revocation, redundancy, and monitoring will improve both **security and reliability** while making the IPSec implementation scalable for an enterprise environment.

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification
- D. Design a high-level implementation workflow

A financial services company requires secure email communication for sensitive transactions. **Pretty Good Privacy (PGP)** and **S/MIME** are both used to provide email security through encryption, authentication, integrity, and digital signatures. The choice depends on usability, scalability, key management, and enterprise integration.

A. Comparison of PGP and S/MIME

Feature	PGP	S/MIME
Full Form	Pretty Good Privacy	Secure/Multipurpose Internet Mail Extensions
Trust Model	Web of Trust	Certificate Authority (CA) based
Key Management	User-managed keys	Digital certificates
Usability	Requires more user involvement	Easier in enterprise environments
Scalability	Moderate	High
Enterprise Integration	Less centralized	Strong integration with enterprise email systems
Digital Signature	Supported	Supported
Encryption	Supported	Supported

PGP is flexible and suitable when users need greater control over their keys.

S/MIME is more suitable for organizations that require centralized certificate management and integration with existing enterprise email infrastructure.

B. Key Management and Trust Models

PGP Trust Model:

PGP generally uses a **Web of Trust** model. Users can verify and sign each other's public keys. Trust is distributed among users rather than being controlled by a single authority.

User A

|

| Trusts

↓

User B ---- Trusts ----> User C

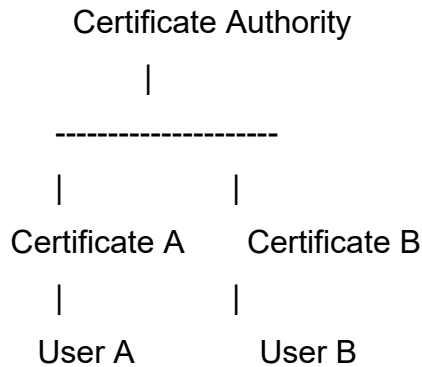
|

↓

Public Key Verification

S/MIME Trust Model:

S/MIME uses a **Certificate Authority (CA)** based trust model. A trusted CA issues digital certificates that bind a user's identity to a public key.



Therefore, PGP provides decentralized trust, while S/MIME provides centrally managed trust.

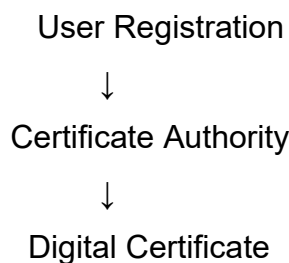
C. Recommended Solution

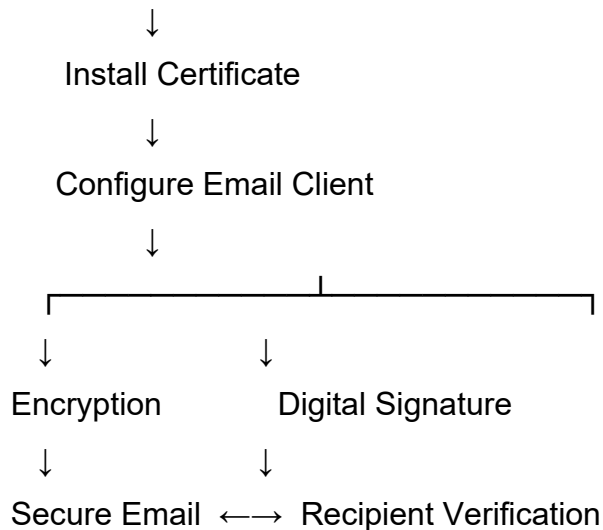
For a **financial services company**, **S/MIME is recommended** because it provides:

1. Centralized certificate management.
2. Strong identity verification through digital certificates.
3. Better enterprise scalability.
4. Easier integration with organizational email systems.
5. Support for encryption and digital signatures.
6. Improved management of certificates and user identities.

PGP can be selected when decentralized trust and user-controlled key management are more important. However, for a large enterprise requiring centralized administration, **S/MIME is the more appropriate choice**.

D. High-Level Implementation Workflow





Implementation Steps:

1. Register employees with the organization's certificate authority.
2. Generate or obtain public and private keys.
3. Issue digital certificates to authorized users.
4. Install certificates in approved email clients.
5. Configure encryption and digital-signature settings.
6. Send encrypted and digitally signed emails.
7. Recipient systems validate the sender's certificate and decrypt the message.

Conclusion

For sensitive financial transactions, **S/MIME is recommended over PGP** because of its centralized trust model, enterprise integration, scalability, and certificate-based identity management. PGP remains useful where decentralized trust and greater user control over keys are required.

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques
- B. Analyze email headers for spoofing indicators

- C. Design an improved detection model (rule-based or ML-based)
- D. Evaluate effectiveness and false positive handling

The company is experiencing an increase in phishing and spam attacks despite using basic filtering mechanisms. An improved detection system should analyze both **email headers and message content** to identify spoofing, suspicious senders, malicious links, and abnormal message patterns.

A. Limitations of Existing Filtering Techniques

Basic filtering mechanisms have several limitations:

1. **Keyword-based filtering** may fail when attackers use modified or disguised words.
2. **Static rules** cannot easily detect new phishing techniques.
3. **Sender-only filtering** may not identify sophisticated spoofed emails.
4. **Limited content analysis** can allow malicious links or attachments to pass through.
5. **High false positives** may cause legitimate emails to be incorrectly classified as spam.

Therefore, the organization requires a more advanced detection approach combining multiple indicators.

B. Email Header Analysis for Spoofing Indicators

Email headers provide important information for identifying suspicious messages.

The system should examine:

- **From address** – Check whether the displayed sender is suspicious or impersonated.
- **Reply-To address** – Identify mismatches with the sender

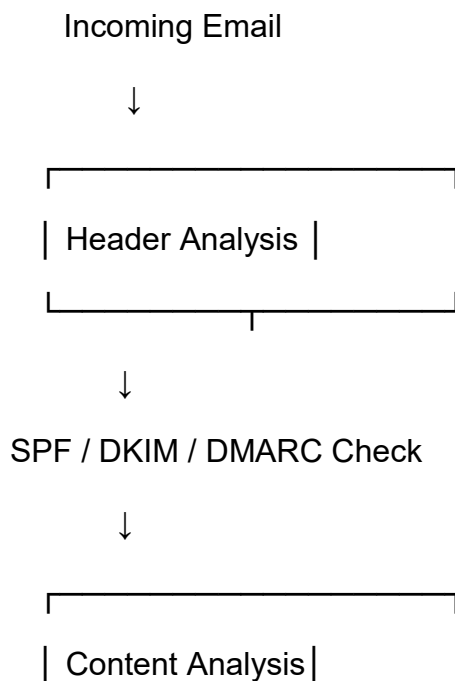
address.

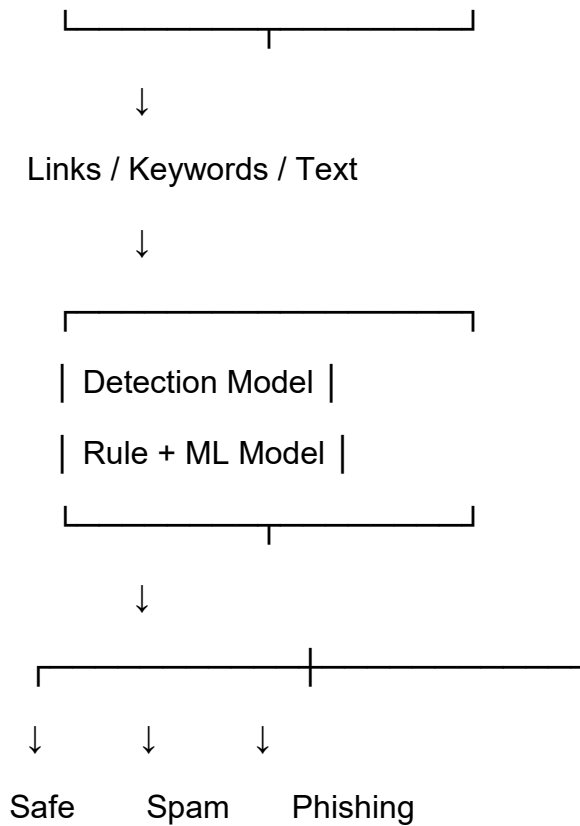
- **Received headers** – Trace the servers through which the email passed.
- **Return-Path** – Check whether the return address is consistent with the sender.
- **SPF results** – Verify whether the sending server is authorized.
- **DKIM results** – Verify the integrity and authenticity of the message.
- **DMARC results** – Check domain alignment and authentication status.

A mismatch between these indicators can increase the probability that an email is phishing or spoofed.

C. Improved Detection Model

A **hybrid detection model** combining rule-based analysis and machine learning can provide better protection.





Detection process:

1. Collect email header information.
2. Verify sender authentication using SPF, DKIM, and DMARC.
3. Analyze message content and suspicious keywords.
4. Inspect URLs and identify suspicious patterns.
5. Extract relevant features from the email.
6. Apply predefined security rules.
7. Use a machine-learning classifier to calculate the likelihood of spam or phishing.
8. Classify the email as **legitimate, spam, or phishing**.

D. Effectiveness and False Positive Handling

The effectiveness of the detection model can be evaluated using:

- **Accuracy**
- **Precision**
- **Recall**
- **F1-score**
- **False Positive Rate**

To reduce false positives:

1. Use multiple detection features instead of a single rule.
2. Maintain a trusted-sender list.
3. Assign different risk scores to different indicators.
4. Allow users to report incorrectly classified emails.
5. Continuously update detection rules and the ML model.
6. Place uncertain emails in a quarantine area instead of immediately deleting them.

Conclusion

The company should replace basic filtering with a **hybrid spam and phishing detection system** that combines email-header analysis, content analysis, authentication checks, rule-based detection, and machine learning. This approach can identify sophisticated phishing attempts while reducing false positives and improving overall email security.

5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

- A. Identify potential certificate-related vulnerabilities
- B. Analyze trust chain and validation process
- C. Propose secure certificate storage and management practices D.
- Recommend improvements for user awareness and system configuration

During the security audit, the company found that encrypted email messages were vulnerable because of improper S/MIME certificate handling. Secure certificate management is essential to ensure that email encryption, digital signatures, authentication, and trust validation work correctly.

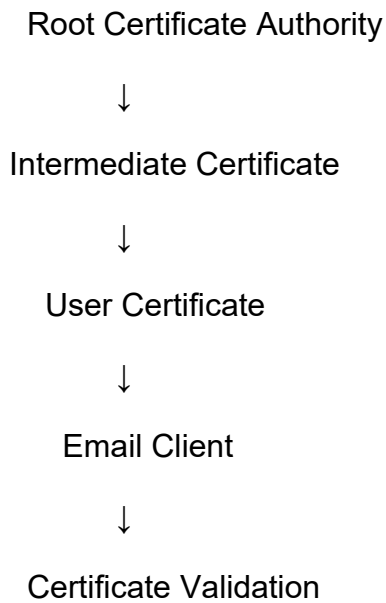
A. Potential Certificate-Related Vulnerabilities

The possible certificate-related vulnerabilities include:

1. **Expired certificates** – An expired certificate may prevent proper validation.
2. **Revoked certificates** – A certificate that has been revoked may still be incorrectly trusted.
3. **Invalid certificates** – Incorrect or improperly issued certificates can create security risks.
4. **Untrusted CA** – Certificates issued by an untrusted Certificate Authority should not be accepted.
5. **Improper private-key protection** – If the private key is exposed, an attacker may impersonate the user or access protected email.
6. **Incorrect certificate configuration** – Improper installation or configuration can cause authentication and validation failures.

B. Trust Chain and Validation Process

S/MIME certificates should be validated through a proper **certificate trust chain**.



The validation process includes:

1. Verify that the certificate is issued by a trusted CA.
2. Validate the complete certificate chain.
3. Check the certificate validity period.
4. Check whether the certificate has been revoked.
5. Verify that the certificate belongs to the intended user.
6. Confirm that the certificate is suitable for its intended purpose.
7. Accept the certificate only when all required validation checks succeed.

This prevents untrusted or invalid certificates from being used for secure email communication.

C. Secure Certificate Storage and Management

The company should implement the following practices:

- Store private keys securely and restrict unauthorized access.
- Protect private keys using strong passwords or secure key-storage mechanisms.
- Never share private keys with other users.

- Maintain a centralized certificate inventory.
- Monitor certificate expiration dates.
- Renew certificates before they expire.
- Immediately revoke compromised certificates.
- Maintain proper backup and recovery procedures for certificates and keys.
- Restrict certificate-management privileges to authorized administrators.

These practices reduce the possibility of certificate theft, misuse, and service interruption.

D. Improvements in User Awareness and System Configuration

The company should improve both user awareness and technical configuration.

User Awareness:

1. Train employees to recognize certificate warnings.
2. Teach users not to ignore invalid or expired certificate alerts.
3. Explain the importance of protecting private keys.
4. Encourage users to report suspicious certificate-related messages.
5. Provide regular security-awareness training.

System Configuration:

1. Configure email clients to validate certificates automatically.
2. Use trusted CA certificates.
3. Enable certificate revocation checking.
4. Configure automatic certificate renewal where possible.
5. Maintain updated certificate stores.
6. Restrict the use of invalid, expired, or revoked certificates.

Conclusion

The company should establish a **centralized and secure S/MIME certificate-management process**. Proper certificate storage, trust-chain validation, expiration monitoring, revocation checking, secure private-key protection, and user awareness will reduce certificate-related vulnerabilities and improve the security of encrypted email communication.